INFORME DE EVALUACIÓN DE SEGURIDAD

Evaluación de Seguridad Ofensiva, Hackeo Ético y Verificación OWASP ASVS v4.0.3

NOVIEMBRE DE 2026

CONFIDENCIAL - REPORTE DE SEGURIDAD E INFORMACIÓN DE AUDITORÍA

Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica ..... Pág. 3

2. Metodología de Evaluación y Estándares Aplicados ..... Pág. 4

2.1 Marcos utilizados ..... Pág. 4

2.2 Escala de severidad y prioridad ..... Pág. 4

3. Gráficos de Distribución (Score (CVSS)) ..... Pág. 5

4. Gráficos de Distribución (Estado del Ticket) ..... Pág. 6

5. Alcance técnico y componentes evaluados ..... Pág. 7

6. Hallazgos identificados ..... Pág. 8

7. Listado Resumido y Detalle de Hallazgos (1 tickets) ..... Pág. 9

8. Conclusiones y plan de remediación recomendado ..... Pág. 11

Resumen Ejecutivo y Ficha Técnica

Este informe presenta los resultados de una revisión pasiva de la página principal de **Promiedos**, realizada como actividad ac adémica del curso Software Seguro.

La evaluación consistió en observar las solicitudes y respuestas HTTP generadas durante la navegación normal, utilizando las herramientas de desarrollador del navegador. No se modificaron peticiones ni se ejecutaron fuzzing, inyecciones o ataques a ctivos.

Se observó la cabecera `X-Powered-By: Next.js`, que identifica el framework utilizado por la aplicación. No se expone una versión concreta ni se demostró una v ulnerabilidad explotable. La observación se clasifica como **informativa**, con **CVSS 3.1 de 0.0**, al no haberse demostrado imp acto en confidencialidad, integridad o disponibilidad.

Parámetro / Campo Detalle de la Evaluación	
Tipo de Evaluación	Revisión pasiva de configuración e información expuesta
Estándar Principal	OWASP ASVS 4.0.3 y CVSS 3.1
Período de Pruebas	9 de Noviembre
Entorno de Evaluación	Sitio público de producción durante navegación normal
Clasificación del Documento	**USO ACADEMICO**

Metodología de Evaluación y Estándares Aplicados

La evaluación se realizó mediante observación pasiva del tráfico HTTP generado durante la navegación normal por la página p rincipal de Promiedos. Se utilizaron las herramientas de desarrollador del navegador para inspeccionar los encabezados de r espuesta y los atributos de las cookies.

Técnicas utilizadas:

- Inspección manual de solicitudes y respuestas HTTP en Network / Red.
- Revisión de encabezados que identifican tecnologías utilizadas.
- Observación de los atributos `Secure`, `HttpOnly` y `SameSite` de las cookies.
- Registro de evidencia mediante capturas de pantalla.

No se modificaron solicitudes ni se realizaron pruebas de inyección, fuzzing, enumeración automatizada o explotación.

Alcance de las pruebas: página principal `https://www.promiedos.com.ar/`, respuesta a `GET /` y cookies visibles en el nav egador durante la observación. No se analizaron servicios de terceros ni componentes internos.

2.1 Marcos utilizados

OWASP ASVS 4.0.3: referencia general para la revisión de configuración e información expuesta. No se verificó el cumpli miento integral de sus requisitos ni se asignó un nivel de cumplimiento.

CVSS 3.1: metodología utilizada para valorar el impacto técnico de la observación.

2.2 Escala de severidad y prioridad

Se utiliza CVSS 3.1 para registrar el puntaje, la severidad y el vector correspondiente.

La exposición de `X-Powered-By: Next.js` se registra como una **observación informativa**, con puntaje **0.0** y vector:

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N`

El puntaje responde a que no se demostró impacto en confidencialidad, integridad ni disponibilidad. Su tratamiento corresp onde a una mejora de configuración, con prioridad inferior a vulnerabilidades con impacto comprobado.

Escala			
Baja (0.1 – 3.9)	Media (4.0 – 6.9)	Alta (7.0 – 8.9)	Crítica (9.0 – 10.0)

Métricas y Distribución Estadísticas de Hallazgos

A continuación se consolidan las métricas obtenidas sobre el estado actual de los hallazgos técnicos registrados durante la a uditoría.



Distribución de los hallazgos según su puntaje CVSS. La gráfica permite comparar su severidad e identificar cuáles requieren mayor atención

Distribución por Estado del Ticket



CATEGORÍA	CANT.	%
Validado	1	100.0%

Total contabilizado: 1

La gráfica muestra la proporción de hallazgos según su estado actual. Esta información permite conocer el avance del seguimiento y de las tareas de corrección

Alcance técnico y componentes evaluados

La revisión abarcó la respuesta HTTP de la página principal de `https://www.promiedos.com.ar/` y las cookies visibles durante la navegación normal.

Encabezados de respuesta: se inspeccionaron los encabezados de la respuesta `HTTP 200 OK` a `GET /`. Se identificó `X-Powered-By: Next.js`, que revela el framework utilizado sin indicar una versión concreta.

Cookies: se observaron las cookies `_ga`, `_ga_JYZI9P25HV` y `ab_bucket`, junto con sus atributos `Secure`, `HttpOnly` y `SameSite`. No se identificaron cookies de autenticación ni se demostró un impacto de seguridad asociado a ellas.

Información de infraestructura: se observaron encabezados que identifican el uso de CloudFront. Su presencia no se consideró por sí sola una vulnerabilidad.

El hallazgo documentado se limita a la exposición del framework mediante la cabecera `X-Powered-By`.

No se evaluaron mecanismos de autenticación, permisos, controles de acceso, validación de entradas, criptografía interna ni registros del servidor. Tampoco se realizaron pruebas activas sobre el sitio o su infraestructura.

Hallazgos identificados

A continuación se documentan los hallazgos confirmados durante la evaluación. Para cada uno se incluyen el resumen, los det alles técnicos, las métricas CVSS, la prueba de concepto paso a paso y las recomendaciones de remediación.

HALLAZGO #1 Validado

Software Seguro v1.0.1

Plantilla: Plantilla
Ref ID: 004

TITULO

Exposición del framework mediante la cabecera X-Powered-By

TIPO

Exposición de tecnología

SEVERIDAD

Informativa

DESCRIPCIÓN

Durante la navegación normal por https://www.promiedos.com.ar/, se observó que la respuesta a GET / incluye la cabecera X-Powered-By: Next.js. Esta información permite identificar el framework utilizado por la aplicación.

No se expone una versión concreta ni se ha demostrado una vulnerabilidad explotable. La observación se realizó de forma pasiva mediante el inspector del navegador, sin modificar solicitudes ni ejecutar ataques.

SCORE

0.0 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N)

IMPACTO

La cabecera facilita la identificación de la tecnología empleada y aporta información para el reconocimiento del sitio. Con la evidencia disponible no se demuestra un impacto directo en la confidencialidad, integridad o disponibilidad.

PRUEBA DE CONCEPTO (POC)

1. Abrir https://www.promiedos.com.ar/ en el navegador.

2. Abrir las herramientas de desarrollador y seleccionar Network / Red.

3. Recargar la página y seleccionar la petición principal GET /, de tipo document.

4. Revisar Headers → Response Headers.

5. Observar que la respuesta HTTP 200 incluye X-Powered-By: Next.js.

Resultado observado: la respuesta identifica públicamente el framework de la aplicación.

Evidencia: captura del inspector donde se visualizan la URL, el estado HTTP y la cabecera indicada.

RECOMENDACIÓN

Omitir la cabecera X-Powered-By en las respuestas de producción. En Next.js, configurar poweredByHeader: false y verificar que la cabecera tampoco sea agregada por otros componentes de la infraestructura. Tras desplegar el cambio, comprobar su ausencia en las respuestas.

Evidencia Multimedia #1

004 - Exposición del framework mediante la cabecera X-Powered-By

Request URL	https://www.promiedos.com.ar/
Request Method	GET
Status Code	200 OK
Remote Address	127.0.0.1:8080
Referrer Policy	strict-origin-when-cross-origin

▼ Response headers

Age	384
Alt-Svc	h3=":443"; ma=86400
Cache-Control	public, max-age=600
Content-Type	text/html; charset=utf-8
Date	Mon, 09 Nov 2026 19:12:20 GMT
Etag	"qxa4texnz615by"
Vary	Accept-Encoding
Vary	Origin
Via	1.1 a7539c5125d12bfd9e4a6b2ed20030ee.cloudfront.net (CloudFront)
X-Amz-Cf-Id	JTZ3NhJyjHwhFY7RyrzzWMOEwWI7HfaPYSBU4QceJdHyZVTPqyTLYQ==
X-Amz-Cf-Pop	MIA50-P2
X-Cache	Hit from cloudfront
X-Powered-By	Next.js

Conclusiones y plan de remediación recomendado

La revisión pasiva permitió identificar que la página principal de Promiedos expone el framework utilizado mediante la cabecera `X-Powered-By: Next.js`. La evidencia se obtuvo observando una respuesta HTTP generada durante la navegación normal, sin modificar solicitudes ni ejecutar ataques.

La observación se clasifica como **informativa**, con **CVSS 3.1 de 0.0**. No se identificó una versión concreta ni se demostró impacto en confidencialidad, integridad o disponibilidad. Su corrección constituye una medida de endurecimiento de la configuración.

Se recomienda al equipo responsable del sitio:

- **Omitir la cabecera `X-Powered-By`** en las respuestas de producción.
- **Revisar los componentes que generan la respuesta**, para evitar que la cabecera sea agregada nuevamente por la aplicación o la infraestructura.
- **Verificar el cambio** mediante la inspección de respuestas obtenidas durante la navegación normal, comprobando que la página continúe funcionando y que la cabecera ya no esté presente.

No se aplicaron cambios al sitio. La revisión fue externa y pasiva; sus resultados no permiten afirmar que el resto de la aplicación esté libre de vulnerabilidades.

Informe elaborado por: Gabriel Agustín, Bertero Jarchum.

Revisión: pendiente.